AIMS
Accounting Information Management System

Production Readiness Remediation Report

Full audit of identified issues, implemented changes, verification evidence and residual production risk

REPORT DATE	8 November 2026
SYSTEM	AIMS multi-company accounting platform
BASELINE	Post-remediation working tree and local Compose deployment
CLASSIFICATION	Confidential - Internal Use
CURRENT VERDICT	**CONDITIONAL NO-GO**

This report distinguishes implemented controls from controls that still require migration, infrastructure, testing or operational evidence. It must not be used as a production approval.

1. Executive summary

The remediation substantially improved AIMS across accounting correctness, tenancy, authentication, authorization, browser security, deployment hardening and user experience. It does not, however, close every finding from the original production-readiness audit.

RESOLVED	MOSTLY RESOLVED	PARTIAL	OPEN
5	2	9	4

CURRENT RELEASE VERDICT	CONDITIONAL NO-GO FOR FINANCIAL PRODUCTION

The architecture now contains the main building blocks of a production accounting platform: a canonical ledger, database-per-company provisioning, TOTP MFA, secure rotating sessions, branch-aware authorization, production fail-fast configuration, real dashboard data and hardened containers. The remaining release blockers are predominantly cutover, data migration, operational proof and comprehensive automated verification.

Highest remaining risks

- The current frontend voucher journey still uses compatibility APIs rather than the canonical posted ledger.
- Existing company data has not been migrated, reconciled and switched to its tenant database.
- Financial integration, isolation, concurrency and end-to-end test coverage remains below release quality.
- Object-storage attachment handling and malware scanning are not implemented.
- Backup/PITR controls and restore objectives are documented but have not been demonstrated through a recorded drill.
- Production TLS, managed secrets, image scanning, signed artifacts, capacity controls and monitoring alerts remain deployment responsibilities.

Material configuration defect identified during reconciliation

compose.yml supplies		`TENANT_DB_JDBC_BASE`
Application expects		`TENANT_DB_JDBC_BASE_URL`

Until corrected, tenant provisioning from the Compose backend can fall back to localhost:5433 inside the container and fail. The required key is TENANT_DB_JDBC_BASE_URL with value jdbc:postgresql://postgres:5432/.

2. Audit basis and verification

This report reconciles the original twenty audit findings against the current uncommitted remediation working tree, platform and tenant Flyway migrations, runtime configuration, Compose deployment, Nginx policy, frontend behavior, CI definition and operations runbook.

Verification completed

Check	Evidence
Backend tests	Passed
Frontend lint	Passed
Frontend production build	Passed
Compose configuration	Valid
Container builds	Passed
Platform migrations	V1-V31 applied
Clean tenant migration	Passed; 18 public tables
Backend health	HTTP 200
Frontend health	HTTP 200
PostgreSQL health	Healthy
Request correlation	X-Request-ID verified
Browser headers	CSP, nosniff and frame denial verified

Important limitations

- No production-sized migration rehearsal or signed financial reconciliation has been completed.
- No load, soak, penetration, failover or backup-restore exercise has been completed.
- No browser assistive-technology walkthrough or WCAG 2.2 AA sign-off has been completed.
- No Java/container SBOM or vulnerability scan is currently enforced in CI.
- The existing company remains PENDING and was not provisioned because the existing administrator password was not changed or reset during verification.

3. Finding-by-finding remediation matrix

Status means: Resolved - implemented and verified at the assessed layer; Mostly resolved - primary control implemented with limited residual work; Partial - meaningful implementation exists but the original production risk is not fully closed; Open - substantial implementation is still required.

ID	Priority / area	Issue and remediation	Status
AIMS-001	P0 Accounting	**Issue:** Active vouchers bypassed the controlled ledger and were limited to DRAFT. **Updated:** Added a canonical tenant ledger with one vouchers table, one voucher_lines table, lifecycle commands, balance and open-period triggers, maker-checker approval, immutable posted entries and reversals. Added versioned canonical APIs with ETags. **Remaining:** The legacy frontend still calls compatibility APIs and existing data has not been migrated or reconciled.	**Partial**
AIMS-002	P0 Tenancy	**Issue:** Database-per-company existed only in documentation. **Updated:** Added immutable tenant keys, physical database registry, provisioning jobs, idempotent database creation, tenant Flyway lineage, metadata synchronization and bounded per-tenant Hikari pools. **Remaining:** The existing company is PENDING; legacy services still use shared tables until cutover.	**Partial**
AIMS-003	P0 Security	**Issue:** Production could start with known development secrets and bootstrap could re-promote an administrator. **Updated:** Added a production profile with mandatory secrets, secure-cookie and HTTPS-origin validation, disabled production bootstrap, and changed bootstrap so it never re-promotes an existing user. **Remaining:** Production must inject secrets through the deployment platform; local Compose deliberately retains development defaults.	**Resolved**
AIMS-004	P0 Quality	**Issue:** Testing, CI, restore evidence and release controls were insufficient. **Updated:** Added CI for backend tests, frontend lint/build and container builds. Replayed platform migrations and the tenant schema against PostgreSQL. Added a recovery runbook. **Remaining:** Integration, concurrency, isolation, frontend E2E, security scanning and restore-drill evidence remain incomplete.	**Partial**
AIMS-005	P1 Authorization	**Issue:** Company permission checks did not consistently enforce assigned branch scope. **Updated:** Centralized branch authorization and allowed-branch filtering across branch, voucher, voucher setup, initial data and canonical voucher lifecycle services. **Remaining:** Negative authorization tests should still be expanded in CI.	**Resolved**
AIMS-006	P1 Database	**Issue:** IDs and copied business codes coexisted without guarantees that they remained consistent. **Updated:** The canonical tenant schema stores dimensions once, uses normalized references, removes organization IDs inside tenant databases and consolidates account/report hierarchies. **Remaining:** Legacy redundant tables remain until migration, reconciliation and retirement.	**Partial**
AIMS-007	P1 Accounting	**Issue:** Voucher creation accepted retries without an idempotency contract. **Updated:** Canonical creation and reversal require Idempotency-Key, persist request hashes and result references, return the original result for identical retries, and reject mismatched reuse. **Remaining:** Legacy voucher endpoints are not idempotent.	**Partial**
AIMS-008	P1 Security	**Issue:** No MFA, network-aware throttling, session inventory or refresh-family theft response. **Updated:** Added encrypted TOTP, recovery codes, ten-minute posting step-up, email/IP throttling, security versions, session inventory/revocation, refresh families, replay detection and family revocation. **Remaining:** No breached-password provider, self-service recovery, asymmetric signing or complete MFA enrollment UI.	**Mostly resolved**
AIMS-009	P1 Security	**Issue:** The application trusted an attacker-controlled first X-Forwarded-For value. **Updated:** Added configured trusted-proxy CIDRs and client-IP resolution that ignores forwarding headers from untrusted peers. Nginx replaces incoming forwarding chains. **Remaining:** Production ingress CIDRs must be configured accurately.	**Resolved**
AIMS-010	P1 Performance	**Issue:** Collection endpoints returned unbounded result sets. **Updated:** Canonical vouchers use stable cursor pagination and bounded page sizes. **Remaining:** Several compatibility/setup endpoints and frontend tables still require server paging and sorting.	**Partial**

3. Finding-by-finding remediation matrix (continued)

ID	Priority / area	Issue and remediation	Status
AIMS-011	P1 Operations	**Issue:** TLS policy, secret management, resource controls and supply-chain controls were absent. **Updated:** Added production fail-fast configuration, read-only containers, dropped capabilities, no-new-privileges, tmpfs write paths, CI container builds and security headers. **Remaining:** TLS ingress, resource limits, digest pinning, SBOM, SCA/image scanning and signed images remain deployment work.	**Partial**
AIMS-012	P1 Recovery	**Issue:** No tested RPO/RTO, PITR or tenant-restore procedure existed. **Updated:** Added an operations runbook targeting 15-minute RPO and 4-hour RTO, with WAL, tenant inventory, quarterly restore and incident procedures. **Remaining:** PITR, cross-domain backup replication and signed restore-drill evidence must be implemented operationally.	**Partial**
AIMS-013	P2 Attachments	**Issue:** Images were stored as database bytea with limited validation. **Updated:** Added canonical attachment metadata, SHA-256, scan status and S3-compatible configuration contract. **Remaining:** Object-storage upload/download, signed URLs, re-encoding, quarantine, malware scanning and legacy migration are not implemented.	**Open**
AIMS-014	P2 Observability	**Issue:** Audit coverage and correlation/metrics contracts were incomplete. **Updated:** Added X-Request-ID generation, MDC propagation, request IDs in problem responses, Prometheus registry, security events, provisioning history, canonical audit and outbox tables. **Remaining:** Central log transport, traces, alerts and an outbox publisher remain open.	**Partial**
AIMS-015	P2 UX	**Issue:** Dashboard balances and counts were hard-coded samples. **Updated:** Replaced samples with tenant-ledger assets, liabilities, P&L;, posted totals, draft/review counts, open period and last posting time, including loading and failure states. **Remaining:** The dashboard requires a successfully provisioned tenant database.	**Resolved**
AIMS-016	P2 Accessibility	**Issue:** Modal focus and custom-select semantics were incomplete. **Updated:** Modal now traps focus, restores the opener, supports Escape, marks the background inert and locks scrolling. **Remaining:** Custom select active-descendant semantics and WCAG manual/automated verification remain incomplete.	**Partial**
AIMS-017	P2 UX/API	**Issue:** Routes lacked capability guards and tables lacked scalable server-driven behavior. **Updated:** Backend branch/capability enforcement was strengthened and canonical vouchers gained pagination. **Remaining:** A frontend capability route guard, forbidden page and server-driven legacy tables remain open.	**Open**
AIMS-018	P2 Maintainability	**Issue:** Large pages/services and compressed one-line components made change risky. **Updated:** New tenant, MFA, session, dashboard and canonical voucher responsibilities were placed in separate services/controllers. **Remaining:** Several existing pages and services remain large and require feature-level decomposition.	**Open**
AIMS-019	P2 Frontend security	**Issue:** Browser hardening headers were missing and login disclosed the admin identity. **Updated:** Added CSP, nosniff, frame denial, referrer and permissions policies; removed the prefilled admin email; set upload and proxy timeouts. **Remaining:** HSTS belongs at the production HTTPS ingress and is not enabled on local HTTP.	**Mostly resolved**
AIMS-020	P3 Performance	**Issue:** The initial JavaScript bundle exceeded 500 kB. **Updated:** Added route-level lazy loading and separated heavy feature/PDF modules. The primary application chunk fell to about 251 kB. **Remaining:** A formal performance budget and continuous measurement should be added.	**Resolved**

4. Accounting and database remediation

Original condition

The active product wrote debit, credit and journal vouchers to three near-identical legacy table families whose status was constrained to DRAFT. That path bypassed the stronger posting, period, balance and immutability controls defined elsewhere. A balanced draft is not a posted accounting entry, so the active workflow could not establish a defensible general ledger.

Implemented design

- One canonical vouchers table and one voucher_lines table, with voucher type represented as data.
- Deferred balance validation, open-period validation and database-enforced posting invariants.
- Maker-checker segregation: a voucher creator cannot approve the same voucher.
- Immutable posted headers and lines, with explicit reversal rather than destructive editing.
- Fiscal years, periods, account hierarchy, normalized dimensions, voucher sequences and opening-balance batches.
- Canonical audit events and outbox events in the same tenant database.
- numeric(24,6) monetary precision and explicit currency/exchange-rate fields.

Canonical command interface

Operation	Control
Create	Mandatory Idempotency-Key; request-hash conflict detection
Read/list	Branch authorization, cursor pagination and ETag
Submit	DRAFT to SUBMITTED with optimistic version
Approve/reject	Capability check, maker-checker rule and audit
Post	Recent MFA, open period, balanced lines and atomic sequence
Reverse	New draft with debit/credit values swapped
Void	Only valid draft transition with audit

Residual risk

The canonical path has not replaced the legacy frontend path. A company-by-company migration must copy dimensions, accounts, balances, setup, drafts and any journals; reconcile row counts, per-account totals, sequence maxima and hashes; then switch routing and freeze the shared records.

5. Database-per-company tenancy

The remediation separates platform identity/authorization data from company accounting data. The platform database retains users, organizations, memberships, roles, permissions, refresh sessions, MFA factors, security events and tenant provisioning state. Each company receives a physical accounting database with no organization_id repeated across its financial tables.

Provisioning sequence

1	Resolve the immutable tenant key and safe database name from the platform registry.
2	Use a dedicated provisioner credential to create the database; the runtime credential must not have CREATEDB in production.
3	Run the db/tenant Flyway lineage against the new database.
4	Synchronize company profile and branch metadata.
5	Record schema version, completion time or sanitized failure details.
6	Evict any stale datasource and resolve future accounting work explicitly by company ID.

Connection safety

- Tenant selection is explicit and does not rely on thread-local state.
- Pools are bounded by per-tenant size, total cached tenants and idle eviction time.
- Platform access is checked before selecting a tenant datasource, and branch scope is checked before commands execute.

Known Compose mismatch

The code and .env.example use TENANT_DB_JDBC_BASE_URL, but compose.yml currently uses TENANT_DB_JDBC_BASE. This must be corrected before the containerized provisioner can be considered reliable.

6. Identity, authentication and authorization

Production configuration

- Production refuses missing or unsafe JWT, MFA, platform database and tenant database secrets.
- Production refuses insecure cookies, enabled bootstrap administration and non-HTTPS non-local CORS origins.
- Bootstrap is conditional and never re-promotes an existing account.
- The login form no longer reveals a default administrator email.

MFA and privileged step-up

TOTP secrets are encrypted with AES-GCM using an environment-provided encryption key. Enrollment requires a valid TOTP code and produces ten hashed, one-time recovery codes. A financial posting requires an MFA verification no older than ten minutes; the verification timestamp is preserved across refresh rotation so refresh does not silently create a new step-up event.

Session and token protection

- JWT issuer, audience, jti, session-family ID and user security version are validated.
- Every authenticated request verifies that the user and session family remain active.
- Refresh tokens are random, SHA-256 hashed, rotated and linked into a family.
- Reuse of a revoked refresh token revokes the family, increments the user security version and records a high-signal security event.
- Users can list active sessions and revoke an individual family.
- Login throttling uses normalized email and network address rather than account lockout alone.

Branch authorization

Branch-bound services now enforce both capability and membership branch scope. Option and list queries filter disallowed branches, and direct object requests reject branch IDs outside the actor's access. This applies to voucher setup, voucher entry, initial data and canonical lifecycle commands.

7. API, user experience and accessibility

API contract improvements

- Versioned /api/v1 canonical routes.
- Explicit create, submit, approve, reject, post, reverse and void commands.
- Mandatory idempotency for canonical financial creation/reversal.
- ETag and If-Match optimistic concurrency.
- Cursor-paged canonical collections.
- Stable problem-detail types with timestamps and request IDs.

Dashboard correction

The hard-coded assets, liabilities, profit/loss, October 2026 period and sample voucher counts were removed. The page now reads posted tenant-ledger values and workflow counts, displays the real open period and last posting time, and includes skeleton, no-company and error states.

Frontend performance

Before	Approximately 594 kB main minified chunk
After	Approximately 251 kB primary application chunk plus lazy feature chunks

Accessibility changes

Modal dialogs now trap focus, support Escape, restore focus to the opener, mark the application root inert and lock background scrolling. Remaining work includes complete combobox active-descendant semantics, accessible dirty-form confirmation, responsive table alternatives and WCAG 2.2 AA testing.

8. Deployment, browser security and observability

Compose hardening

- Backend and frontend filesystems are read-only.
- Linux capabilities are dropped and no-new-privileges is enabled.
- Only required temporary paths are writable through tmpfs.
- Service startup is health-dependent.
- Tenant runtime and provisioner credentials are represented separately.

The Compose file is a local-development deployment, not a production manifest. Its default JWT/database/admin values, HTTP CORS origin and insecure cookies must never be used for production. Production must activate the prod Spring profile and inject platform-managed secrets.

Nginx and browser policy

Header	Policy
Content-Security-Policy	Self-only default; blocks objects/framing; restricts scripts, forms and connections
X-Content-Type-Options	nosniff
X-Frame-Options	DENY
Referrer-Policy	strict-origin-when-cross-origin
Permissions-Policy	Disables camera, microphone, geolocation, payment and USB

HSTS must be configured at the production HTTPS ingress rather than on the local HTTP server.

Observability

Every request receives an X-Request-ID, which is returned in problem details and placed in logging MDC. Prometheus export, security events, tenant provisioning events, canonical audit events and an outbox schema were added. Central log delivery, tracing, alert rules and an outbox publisher remain open.

9. Recovery, attachments and operational controls

Recovery objectives

Objective	Target	Current evidence
RPO	15 minutes	Documented; WAL/PITR not demonstrated
RTO	4 hours	Documented; restore drill not demonstrated

The runbook requires encrypted base backups, continuous WAL archiving, tenant inventory from the platform registry, separate failure domains, quarterly isolated restores, migration validation and recorded recovery time. These are operational acceptance criteria, not evidence that the controls are already running.

Attachments

The canonical design stores object key, media type, size, SHA-256, scan status, uploader and timestamp in PostgreSQL while file bytes belong in private S3-compatible storage. Only the metadata model and configuration contract exist today. The adapter, signed downloads, malware quarantine, image re-encoding, metadata stripping, resource limits, retention and legacy bytea migration remain open.

Incident response

- Preserve request IDs, security events, application logs, database logs and infrastructure audit records.
- Revoke the affected session family or increment user security_version for complete user revocation.
- Rotate JWT, MFA-encryption, database and object-storage credentials through the secret manager.
- Record scope, timeline, containment, recovery and corrective actions.

10. Production release blockers and roadmap

#	Blocker	Required closure
1	Canonical cutover	Move voucher UI/workflows to the canonical API and stop new writes to legacy ledger tables.
2	Migration and reconciliation	Provision every tenant, migrate company data, reconcile exact balances/sequences/hashes and obtain finance sign-off.
3	Verification	Add PostgreSQL integration, cross-tenant/branch denial, concurrency, frontend component/E2E and accessibility tests.
4	Attachments	Implement private object storage, authorized retrieval, malware scanning and binary-data migration.
5	Recovery evidence	Enable PITR and complete a timed platform-plus-tenant restore drill within the approved objectives.
6	Production platform	Configure TLS, managed secrets, resource budgets, monitoring/alerts, scans, SBOM, signed digest-pinned images and rollout controls.
7	Configuration correction	Rename TENANT_DB_JDBC_BASE to TENANT_DB_JDBC_BASE_URL in Compose and re-test provisioning.

Recommended closure sequence

- Immediate: correct Compose configuration, add canonical integration tests and provision a non-production pilot tenant.
- Pilot: migrate one company in a maintenance window, reconcile, switch the UI and monitor without dual-writing.
- Operational: implement object storage, telemetry, alerting, security scanning and backup/PITR.
- Release rehearsal: repeat migration with production-sized data, perform restore/failure tests and complete WCAG/E2E verification.
- Approval: obtain accounting owner, security, DBA/SRE and product-owner sign-off on residual risk and release evidence.

11. Release acceptance checklist

State	Acceptance condition
OPEN	Every financial workflow uses the canonical tenant ledger; legacy writes are disabled.
OPEN	Submit, approve, reject, post, reverse, void and period-close duties are separated and tested.
DONE	Canonical posted vouchers are balanced, open-period controlled, immutable and reversible.
OPEN	All production companies are physically isolated, migrated and reconciled.
DONE	Production startup refuses development defaults and unsafe cookie/origin configuration.
DONE	MFA, posting step-up, refresh-family replay response and session revocation exist.
OPEN	All material APIs and tables have bounded pagination and performance evidence.
OPEN	CI enforces integration, authorization, concurrency, frontend, E2E and security gates.
OPEN	PITR and tenant restore have met the signed 15-minute RPO and 4-hour RTO.
OPEN	Logs, metrics, traces, alerts and outbox publishing are operational.
DONE	Sample financial dashboard data has been removed.
OPEN	WCAG 2.2 AA and browser/device journeys have been signed off.
OPEN	Security, accounting, operations and product owners have approved release evidence.

Conclusion

AIMS now has a substantially stronger architecture and a credible path to financial-grade operation. The implemented controls should be preserved, but production approval must wait for canonical cutover, reconciled tenant migration, object-storage completion, comprehensive test evidence and demonstrated operational recovery.